

¿Es *Health Connect* la mejor garantía de Seguridad y Privacidad para los datos de salud?

Alejandro Pérez-Fuente

Grupo de Ingeniería de la Privacidad (IngPriv)
Universidad de Valladolid, España
alejandro.perez.fuente@uva.es

Amador Aparicio

Grupo de Ingeniería de la Privacidad (IngPriv)
Universidad de Valladolid, España
amador@infor.uva.es

M. Mercedes Martínez-González

Grupo de Ingeniería de la Privacidad (IngPriv)
Universidad de Valladolid, España
mercedes@infor.uva.es

Pablo A. Criado-Lozano

Grupo de Ingeniería de la Privacidad (IngPriv)
Universidad de Valladolid, España
Universidad Europea Miguel de Cervantes, España
pacriado@uemc.es

Resumen—Ante la creciente preocupación por la seguridad y privacidad de los datos de salud, con la llegada de Android 14, se introduce *Health Connect*, una plataforma que busca mejorar su gestión y permite a los usuarios un mayor control.

Pero, ¿es *Health Connect* una mejora en seguridad y privacidad frente a las soluciones utilizadas previamente? En este trabajo se responde a esta pregunta mediante un análisis novedoso que combina tanto los criterios de seguridad como los de privacidad emanados de la normativa. El análisis incluye su comparación frente a soluciones pasadas, como Google Fit y la API de Sensores de Android.

Los resultados muestran que *Health Connect* es la solución que aporta mejor protección de la información mediante almacenamiento local, cifrado y permisos más específicos. Sin embargo, aún debe abordar desafíos como la falta de transparencia en la documentación, que pueden afectar su adopción y confiabilidad.

Index Terms—Seguridad, Privacidad, Aplicaciones Móviles, Metadatos, Salud, Android

Tipo de contribución: Investigación original (límite 8 páginas)

I. INTRODUCCIÓN

La seguridad y la privacidad en las aplicaciones de salud son temas de creciente importancia [1], [2]. Con el aumento del uso de dispositivos móviles y plataformas tecnológicas para el monitoreo y manejo de la salud, los usuarios comparten constantemente datos sensibles, como información médica personal y biométrica [3]. Esta recopilación y el constante intercambio de información de salud entre distintas aplicaciones presentan riesgos significativos, ya que, si no se protegen adecuadamente, estos datos podrían quedar expuestos a usos indebidos. Por tanto, desarrollar mecanismos efectivos de protección y control de acceso es crucial para salvaguardar la integridad de los sistemas donde se intercambian datos de salud y evitar posibles brechas de seguridad y privacidad.

En este contexto, Android, el sistema operativo más utilizado en dispositivos móviles [4], juega un papel crucial en el ecosistema de las aplicaciones de salud. Tanto los *wearables* como las aplicaciones de salud se conectan y funcionan con Android. Por tanto, en última instancia, la seguridad de los datos sensibles depende de lo seguro que sea este sistema operativo. La creciente preocupación por la seguridad y la privacidad en los dispositivos móviles radica,

en parte, en la dificultad de proteger los datos personales de manera específica para cada aplicación, lo que expone a los usuarios. Hasta ahora, Android ha presentado una notable falta de granularidad en el control de acceso a los recursos y datos sensibles del dispositivo [5].

Poco a poco, Android ha ido implementando cambios que han transformado la manera en que las aplicaciones acceden, almacenan y comparten información personal¹. Uno de los avances más significativos es la introducción de *Health Connect*, anunciado en la Google I/O de 2022² como una plataforma destinada a redefinir la gestión de los datos de salud en Android. Esta plataforma comenzó a operar con la llegada de Android 14 en octubre de 2023.

Se ha planteado la cuestión que motiva este estudio: ¿Supone *Health Connect* un avance significativo en términos de seguridad y privacidad frente a las soluciones que la preceden? Más aún: ¿en ambos, quizá solo uno de ellos, o incluso en ninguno de ellos? Para responder a estas preguntas, se ha llevado a cabo un análisis innovador y detallado sobre la repercusión de *Health Connect* en la seguridad y privacidad de la información de salud en Android 14, destacando su impacto frente a soluciones anteriores. Se ha diseñado un método de análisis que se estructura en dos fases complementarias que permiten una comprensión integral de la repercusión de esta tecnología.

En la primera fase, se examinan en profundidad las funcionalidades de *Health Connect* en el contexto del sistema operativo Android 14. Se ha puesto especial atención en los mecanismos de seguridad de los datos y de gestión del acceso a la información de salud. Este análisis es imprescindible para comprender el funcionamiento de la plataforma y detectar los aspectos que pueden influir en la seguridad y privacidad de los usuarios. En la segunda fase, se hace un análisis sistemático guiado por los requisitos de seguridad y privacidad, evaluando hasta qué punto *Health Connect* satisface estos requisitos en comparación con soluciones anteriores. Este enfoque permite valorar la calidad de *Health Connect* y responder a las preguntas que han motivado este estudio.

¹<https://support.google.com/googleplay/android-developer/answer/9888170>

²<https://hackernoon.com/google-io-2022-key-announcements-for-developers>

El resto del artículo se organiza de la siguiente manera. En la sección II, se revisa el estado del arte sobre la gestión de recursos y datos sensibles en Android. En la sección III, se analizan los estudios previos relacionados con la seguridad y privacidad de los datos de salud, así como el almacenamiento seguro, el cifrado y las normativas aplicables. En la sección IV, se examinan los cambios introducidos por *Health Connect* en los mecanismos de protección de datos y de gestión del acceso a la información en Android. En la sección V, se estudian las repercusiones de estos cambios sobre la seguridad y la privacidad en comparación con otras soluciones. En la sección VI, se analizan los desafíos asociados a la adopción de *Health Connect* en Android. En la sección VII, se presentan las conclusiones. Finalmente, en la sección VIII, se proponen posibles líneas de trabajo futuro.

II. ESTADO DEL ARTE

El componente del sistema operativo Android responsable de gestionar el acceso a los recursos y datos sensibles del dispositivo es el modelo de seguridad de Android. De manera más específica, es el modelo de permisos, que constituye una parte fundamental de este sistema de seguridad.

Con el fin de mejorar la seguridad y privacidad de los usuarios, el modelo de permisos de Android ha experimentado una evolución significativa desde su introducción en 2008. En sus primeros años, las aplicaciones solicitaban permisos únicamente durante la instalación, otorgando acceso completo a diversas funcionalidades del dispositivo. Con la llegada de Android 6, se implementó un modelo de permisos en tiempo de ejecución, lo que permitió a los usuarios otorgar o revocar permisos según sus necesidades [6]. Más tarde, con Android 11, se introdujeron permisos más granulares para el acceso a la ubicación, el micrófono y la cámara, ofreciendo a los usuarios un control más detallado sobre qué datos y funcionalidades podían ser accedidos por las aplicaciones. Además, Android 13 continuó esta evolución al incorporar permisos específicos para diferentes tipos de archivos multimedia, como imágenes, vídeos y audios, reemplazando el permiso general de almacenamiento externo [7].

Estos cambios reflejan el esfuerzo continuo de Google por ofrecer a los usuarios un control más preciso sobre los datos y funcionalidades a los que las aplicaciones pueden acceder. En principio, estas modificaciones buscan mejorar la experiencia de los usuarios, reforzando su seguridad y privacidad. El cambio más reciente en esta línea es la introducción de *Health Connect*, que se aborda en las secciones IV y V.

III. TRABAJO RELACIONADO

El cumplimiento de normativas como el Reglamento General de Protección de Datos (RGPD) en Europa [8] o la Ley de Portabilidad y Responsabilidad del Seguro Médico (HIPAA) en EE. UU. [9] es obligatorio y fundamental para garantizar la seguridad y privacidad de los datos en las aplicaciones de salud. Sin embargo, diversos estudios han demostrado que muchas de estas aplicaciones no cumplen completamente con dichas regulaciones, ya sea por falta de transparencia en el manejo de los datos [10], [11], [12], ausencia de mecanismos adecuados de gestión del acceso a los datos o deficiencias en las medidas de seguridad implementadas [13], [10], [11].

En numerosos casos, el cifrado de los datos es insuficiente, lo que puede dar lugar a filtraciones de datos personales, incluidos datos sensibles como credenciales, localización y otros, que se transmiten a través del protocolo HTTP sin cifrado en tránsito [14], [15]. De hecho, diversas investigaciones han demostrado que las aplicaciones que emplean protocolos inseguros o que almacenan información sensible sin cifrar son más vulnerables a ataques por parte de actores malintencionados, lo que facilita las filtraciones de datos [16], [17]. Sin embargo, estos estudios no abordan el caso de *Health Connect*, dado que su implementación es reciente, lo que crea un vacío en la literatura respecto a su impacto en la seguridad y privacidad en la gestión de datos en aplicaciones móviles.

Como se mencionó en la sección I, el modelo de seguridad de Android presenta un problema de granularidad en la gestión del acceso a recursos y datos sensibles. Esto afecta especialmente a las aplicaciones de salud, ya que los permisos que solicitan proporcionan acceso a una amplia gama de datos con un solo permiso, como `BODY_SENSORS`, que da acceso a los datos de sensores de salud, o `READ_EXTERNAL_STORAGE`, que permite acceder a cuantos datos se almacenen en el almacenamiento externo del dispositivo [18]. Este enfoque puede comprometer el cumplimiento de normativas como el Reglamento General de Protección de Datos, que exige un acceso más restringido y controlado a los datos personales, así como la obtención de un consentimiento explícito para cada tipo de dato [18], [16]. Además, la falta de granularidad en los permisos incrementa el riesgo de violaciones del RGPD [16], lo que resulta en riesgos para la privacidad de los usuarios.

IV. SUBIENDO LA GRANULARIDAD EN ANDROID

Como se ha mencionado en la sección II, Android ha refinado progresivamente su modelo de permisos para ofrecer a los usuarios un control más preciso y detallado sobre los recursos de sus dispositivos. A continuación, se analizan los cambios introducidos en Android 14, con especial énfasis en los mecanismos de seguridad de los datos y de gestión del acceso a la información de salud. Este análisis es fundamental para evaluar su impacto en la seguridad y privacidad de la información de salud del usuario.

IV-A. Evolución del recurso al dato en Android 14

En versiones anteriores a Android 14, las aplicaciones que requieren acceso a datos de salud utilizan la API (*Application Programming Interface*) de sensores de Android³. Los sensores *hardware*, como el podómetro o el sensor de frecuencia cardíaca, pueden consultarse a través de la clase `SensorManager`, siempre que la aplicación cuente con el permiso `BODY_SENSORS` [19]. Una vez concedido este permiso, las aplicaciones pueden acceder de manera continua a los datos sin necesidad de solicitar confirmaciones adicionales al usuario.

Este modelo de acceso presenta varias limitaciones. Por ejemplo, si una aplicación solo necesita un dato específico, como la presión arterial, debe solicitar el permiso `BODY_SENSORS`, el cual otorga acceso a todos los sensores de salud del dispositivo, incluso a aquellos que la aplicación

³<https://developer.android.com/reference/android/hardware/Sensor>

no requiere⁴. Esta falta de granularidad en la gestión del acceso a datos ha generado preocupaciones sobre la seguridad, la privacidad y el control del usuario [14], [20].

Una alternativa para gestionar los datos de salud es la sincronización con Google Fit, un servicio basado en computación en la nube que permite a las aplicaciones acceder a esta información a través de su plataforma. Aunque se trata de una solución ampliamente utilizada, dejará de estar disponible a partir del 30 de junio de 2025⁵. Este enfoque conlleva riesgos inherentes a la computación en la nube, especialmente en términos de seguridad y control de acceso [21]. Al depender de un servicio externo, los datos de salud deben transmitirse y almacenarse fuera del dispositivo, lo que amplía la superficie de ataque en comparación con el acceso directo a los sensores. Esta externalización expone la información a posibles vulnerabilidades en la infraestructura del proveedor, aumentando el riesgo de accesos no autorizados o filtraciones de datos [22]. Por tanto, los usuarios deben confiar en cómo Google gestiona todos estos riesgos. Además, el almacenamiento en la nube limita el control directo por parte de los usuarios sobre el acceso a sus propios datos, a diferencia de una solución local, donde la información permanece en el dispositivo y bajo el dominio exclusivo del usuario.

Finalmente, desde Android 14, *Health Connect* supone un cambio de modelo en el control de acceso en el sistema operativo. Donde antes el único elemento sobre el que se otorgaban permisos era el recurso, ahora se introduce la posibilidad de solicitar permiso para acceder a un dato concreto. Este cambio, cuya trascendencia podría pasar desapercibida para los desarrolladores poco familiarizados con el reto que supone cumplir adecuadamente con los estrictos requisitos de privacidad derivados de la normativa en vigor, es en realidad un cambio sustancial: el nivel de granularidad con el que se puede trabajar aumenta. Ya no se tiene acceso al conjunto de datos de salud en bloque. Ahora se accede a cada dato de salud individualmente.

IV-B. *Health Connect*

Health Connect es una solución creada por Android para centralizar y gestionar la información de salud localmente en el dispositivo del usuario. Su objetivo es unificar el acceso a esta información, facilitando la interoperabilidad entre diversas aplicaciones mediante un modelo seguro y eficiente de intercambio de datos. A partir del 28 de mayo de 2025⁶, la implementación de *Health Connect* será obligatoria para los desarrolladores de aplicaciones de salud en Android. *Health Connect* se compone de varios elementos clave, entre los cuales destacan: una API de sincronización y una aplicación de gestión.

IV-B1. API de sincronización: Este componente permite a los desarrolladores acceder al almacén de datos de salud de *Health Connect*, actuando como un repositorio intermedio que facilita la integración entre distintas aplicaciones. Su objetivo es garantizar que la información se mantenga actualizada

y accesible únicamente para las aplicaciones autorizadas, mejorando así la interoperabilidad y la seguridad de los datos. Desde octubre de 2023, con el lanzamiento de Android 14, esta API está integrada en el sistema operativo como parte de la biblioteca *Jetpack Health*⁷, proporcionando una solución nativa y más eficiente para la gestión de datos de salud.

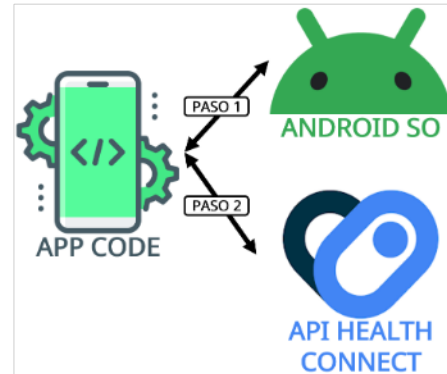


Figura 1. Interacción de una aplicación con Android y *Health Connect*

En la figura 1 se ilustra cómo una aplicación interactúa con la API de *Health Connect* para su funcionamiento. A diferencia de otras soluciones, como la API de Sensores de Android o Google Fit, donde la aplicación interactúa directamente con un solo componente, la implementación de la API de *Health Connect* requiere un acceso en dos etapas. Como preparativos a la interacción, la aplicación debe declarar y solicitar los permisos necesarios dentro del archivo `AndroidManifest.xml` para acceder a los datos específicos, asegurándose también de que el sistema operativo en el que se ejecuta sea compatible con *Health Connect*, lo que implica añadir su SDK (*Software Development Kit*) como dependencia en el archivo `build.gradle`. En el siguiente recuadro se muestran dos fragmentos de código extraídos de dos de estos ficheros, `AndroidManifest.xml` y `build.gradle`.

```
App AndroidManifest.xml
<uses-permission android:name="android.permission.health.READ_HEART_RATE"/>

App build.gradle
dependencies {
    implementation "androidx.health.connect:connect-client:1.1.0-alpha11"
}
```

En el primer paso, la aplicación solicita acceso al componente *Health Connect* a través del punto de entrada `HealthConnectClient` del sistema operativo. Una vez que se obtiene el componente y se conceden los permisos necesarios, en el segundo paso, la aplicación interactúa con la API de *Health Connect* y realiza las operaciones requeridas.

Una de las características clave de seguridad de *Health Connect* es que dentro de su almacén, según Google, los datos se encuentran cifrados⁸. Sin embargo, la documentación

⁴https://developer.android.com/reference/android/Manifest.permission#BODY_SENSORS

⁵<https://developers.google.com/fit/android>

⁶<https://support.google.com/googleplay/android-developer/table/12921780?hl=en>

⁷<https://developer.android.com/jetpack/androidx/releases/health>

⁸<https://developer.android.com/codelabs/health-connect#0>

```

HealthConnectClient.kt
60
61 /**
62  * Inserts one or more [Record] and returns newly assigned
63  * [androidx.health.connect.client.records.metadata.Metadata.id] generated. Insertion of
64  * multiple [records] is executed in a transaction - if one fails, none is inserted.
65  *
66  * @param records List of records to insert
67  * @return List of unique identifiers in the order of inserted records.
68  * @throws android.os.RemoteException For any IPC transportation failures.
69  * @throws SecurityException For requests with unpermitted access.
70  * @throws java.io.IOException For any disk I/O issues.
71  *
72  * For example, to insert basic data like step counts:
73  *
74  * @sample androidx.health.connect.client.samples.InsertSteps
75  *
76  * To insert more complex data like nutrition for a user who's eaten a banana:
77  *
78  * @sample androidx.health.connect.client.samples.InsertNutrition
79  *
80  * To insert some heart rate data:
81  *
82  * @sample androidx.health.connect.client.samples.InsertHeartRateSeries
83  *
84  * [androidx.health.connect.client.records.metadata.Metadata.clientRecordId] can be used to
85  * deduplicate data with a client provided unique identifier, when a subsequent [InsertRecords]
86  * is called with the same
87  * [androidx.health.connect.client.records.metadata.Metadata.clientRecordId], whichever [Record]
88  * with the higher
89  * [androidx.health.connect.client.records.metadata.Metadata.clientRecordVersion] takes
90  * precedence.
91  */
92 suspend fun insertRecords(records: List<Record>): InsertRecordsResponse
    
```

Figura 2. Almacenamiento en *Health Connect*

oficial no especifica ni el algoritmo de cifrado utilizado ni el mecanismo de gestión de las claves.

Para descubrir su funcionamiento, se ha analizado el código de *Health Connect*. En la Figura 2 se muestra un fragmento del código de *Health Connect* en el que se realiza el almacenamiento de un registro de salud. En este, se observa cómo el registro sin cifrar se envía para su almacenamiento a través de un mensaje que ingresa en Android IPC (*Inter-Process Communication*). Por lo tanto, el proceso responsable de almacenar y cifrar los datos es otro componente del sistema operativo Android.

Este cifrado, junto con el acceso en dos pasos, en nuestra opinión, puede ser una fuente de mayor seguridad y privacidad, como argumentaremos en la sección V.

IV-B2. Aplicación de gestión: Este componente ofrece a los usuarios un control minucioso sobre el acceso a sus datos de salud almacenados en *Health Connect*. Permite gestionar de forma precisa qué aplicaciones pueden acceder a cada tipo de dato y definir si dicho acceso será de solo lectura o incluirá también la escritura, mediante la concesión o revocación de permisos. Se incorpora de manera nativa en los dispositivos con Android 14 y está disponible para su descarga en Play Store.

La figura 3 muestra cómo gestionar los permisos de una aplicación hipotética llamada “Fitness App” a través de *Health Connect*. Como se puede observar, la aplicación de gestión ofrece un acceso en bloque a todos los datos de salud mediante una opción de “Permitir todo”. Sin embargo, si los usuarios desean un control más detallado, pueden gestionar los permisos de forma granular mediante dos listas separadas: una para los permisos de lectura de datos y otra para los de escritura. En la figura, la primera lista corresponde a los datos a los que la aplicación tiene permiso para acceder en modo lectura, en este caso, las calorías quemadas. La segunda lista muestra los datos que la aplicación puede escribir, que en este ejemplo son las calorías ingeridas.

El nivel de granularidad en el control del acceso a los datos de salud ha aumentado notablemente respecto a las soluciones anteriores. En la sección V se discute su efecto sobre los dos aspectos que nos interesan: seguridad y privacidad.

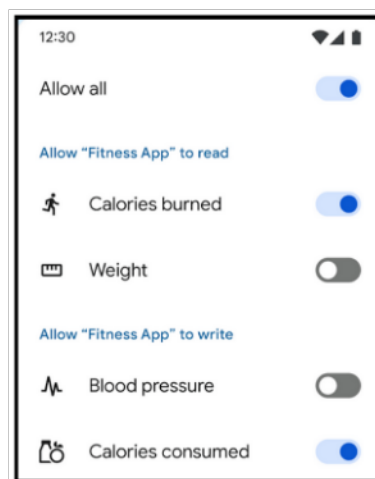


Figura 3. Gestión de datos dentro de la aplicación *Health Connect*.

V. REPERCUSIÓN DE HEALTH CONNECT SOBRE LA SEGURIDAD Y PRIVACIDAD

Al inicio de la sección IV se detectaron lo que podrían ser algunas de las posibles alternativas a *Health Connect*, entre las que destacan la API de Sensores de Android y Google Fit. Posteriormente, en esa misma sección, al analizar qué es y cómo funciona *Health Connect*, se señalaron ciertas características clave que podrían repercutir en la seguridad y la privacidad, como el acceso en dos pasos al almacén, el cifrado de los datos y la mayor granularidad en la gestión del acceso a la información.

Partiendo de las distintas alternativas identificadas y de las características clave, se plantea un análisis comparativo de la seguridad y la privacidad de *Health Connect* frente a sus alternativas, basándose en la documentación oficial de cada uno de estos sistemas. En primer lugar, se definen los criterios de comparación a utilizar. A continuación, se elabora una tabla que aplica estos criterios a cada una de las alternativas. Finalmente, se analizan los resultados obtenidos y se examinan otras posibles repercusiones en materia de seguridad y privacidad. De esta forma, se obtiene una visión clara de la calidad de *Health Connect* y de su contribución a la mejora de la seguridad y privacidad de los datos de salud en el ecosistema Android.

V-A. Seguridad en *Health Connect*

La seguridad informática se sustenta en varios pilares esenciales que protegen la información en entornos digitales⁹. De entre estos, analizaremos aquellos que están relacionados con los datos de salud.

Confidencialidad Garantiza que los datos sean accesibles únicamente para quienes cuentan con la autorización correspondiente, evitando filtraciones o accesos indebidos.

Integridad Asegura que la información se mantenga exacta y libre de modificaciones no autorizadas, preservando su veracidad y consistencia. Es especialmente crucial garantizarla durante la transmisión de los datos.

⁹<https://unirfp.unir.net/revista/ingenieria-y-tecnologia/principios-seguridad-informatica/>

Disponibilidad Se encarga de que tanto los sistemas como los datos estén a disposición de los usuarios autorizados cuando se requieran, evitando interrupciones o bloqueos en el servicio.

Autenticidad Verifica la identidad de los usuarios y la procedencia de la información, estableciendo una base sólida de confianza en las comunicaciones y transacciones digitales.

Estos pilares son esenciales para evaluar la seguridad de cada propuesta. No obstante, garantizar su cumplimiento absoluto en cada solución es un desafío complejo que excede el alcance de este análisis. En su lugar, se evalúa en qué medida cada solución logra aproximarse a la garantía de cada pilar bajo ciertas circunstancias específicas. Se parte de la base que, como usuarios o desarrolladores, solo tenemos control sobre lo que ocurre localmente. Además, se asume que ni el dispositivo ni el sistema operativo están comprometidos.

Teniendo en cuenta estas consideraciones, la tabla I presenta una comparativa de seguridad entre *Health Connect*, Google Fit y la API de Sensores de Android. En cada fila se presenta la evaluación de cada criterio (Pilar de Seguridad) para las diferentes soluciones analizadas: *Health Connect*, Google Fit y la API de Sensores de Android. Para cada una de ellas se indica si es capaz de aportar a los desarrolladores mecanismos suficientes para garantizarla (Sí/No) y las razones que justifican este valor. Un “Sí” significa que los desarrolladores tienen suficientes instrumentos para ello, mientras que un “No” corresponde a la situación en que los desarrolladores se ven obligados a buscar mecanismos externos/ajenos a la solución estudiada para alcanzar ese criterio de seguridad. Por ejemplo, Google Fit por sí mismo no es capaz de garantizar la confidencialidad. Una de las razones es la operación remota que supone el uso de la nube.

Evaluación del cumplimiento de cada uno de los pilares de seguridad seleccionados por *Health Connect*:

- **Confidencialidad:** *Health Connect* garantiza un alto nivel de confidencialidad gracias a su implementación local, que dificulta la interceptación de datos por parte de actores externos. Además, su almacén de datos está cifrado, lo que protege la información incluso en caso de accesos no autorizados a nivel local. Su sistema de gestión de acceso, altamente granular, permite un control preciso sobre qué aplicaciones pueden acceder a los datos, reforzando aún más la confidencialidad. Este aspecto es abordado dentro del modelo de seguridad de Android [6].
- **Integridad:** *Health Connect* garantiza la integridad de los datos al realizar los accesos de manera local, evitando modificaciones durante la transmisión. Además, los mecanismos de protección implementados en el sistema restringen los accesos no autorizados, impidiendo así alteraciones indebidas en la información almacenada [6].
- **Disponibilidad:** *Health Connect* garantiza una alta disponibilidad de los datos al operar de manera local en el dispositivo. Excepto en casos de fallos de *hardware* que afecten la memoria, la información almacenada en *Health Connect* permanece siempre accesible, sin depender de la conectividad a internet ni de servicios externos.
- **Autenticidad:** *Health Connect* garantiza la autenticidad

de los datos a través de un sistema granular de gestión de accesos, que permite identificar qué aplicaciones están autorizadas para introducir información. De este modo, se asegura que los datos provienen de fuentes legítimas y confiables.

Evaluación del cumplimiento de cada uno de los pilares de seguridad seleccionados por Google Fit:

- **Confidencialidad:** En Google Fit, la confidencialidad depende en gran medida de la gestión de datos por parte de Google, ya que se trata de un servicio en la nube. A diferencia de *Health Connect*, el acceso a los datos se basa en permisos generales, lo que permite que cualquier aplicación con autorización pueda visualizar toda la información almacenada en la plataforma. Esta falta de granularidad en la gestión de permisos dificulta garantizar la confidencialidad a nivel individual.
- **Integridad:** La integridad de los datos en Google Fit no puede garantizarse plenamente, ya que, al ser una solución basada en la nube, está expuesta a vulnerabilidades que podrían comprometer la veracidad y consistencia de la información [22]. Factores como fallos de seguridad en los servidores o accesos no autorizados pueden afectar la fiabilidad de los datos almacenados.
- **Disponibilidad:** En Google Fit, la disponibilidad de los datos no está completamente garantizada, ya que al depender de la nube, puede verse afectada por interrupciones en la conectividad o fallos en los servidores de Google [23]. Problemas de red o mantenimiento de la plataforma pueden limitar el acceso a la información cuando se requiera.
- **Autenticidad:** Google Fit cumple con el criterio de autenticidad al incorporar un mecanismo que indica la fuente de los datos¹⁰. Este sistema permite verificar el origen de la información almacenada en la plataforma, asegurando su trazabilidad y fiabilidad.

Evaluación del cumplimiento de cada uno de los pilares de seguridad seleccionados por la API de Sensores de Android:

- **Confidencialidad:** La API de Sensores de Android no proporciona mecanismos para garantizar la confidencialidad de los datos recopilados. Al no contar con un sistema de gestión de acceso granular, cualquier aplicación con los permisos adecuados puede acceder a la información de los sensores sin restricciones específicas. Esta falta de control detallado impide garantizar la confidencialidad de los datos registrados.
- **Integridad:** La API de Sensores de Android asegura la integridad de la información, dado que los accesos se realizan localmente, eliminando el riesgo de modificaciones durante la transmisión. Además, el acceso a los sensores está protegido, lo que evita que aplicaciones no autorizadas puedan alterar los datos capturados.
- **Disponibilidad:** La API de Sensores de Android ofrece una disponibilidad total siempre que el dispositivo funcione correctamente. Dado que el acceso a los datos se realiza localmente, solo fallos de *hardware*, como problemas en los sensores o en la memoria del dispositivo, podrían impedir la recolección y consulta de la información en tiempo real.

¹⁰<https://developers.google.com/fit/android/data-attribution>

Pilar de Seguridad	Soluciones				
	Health Connect		Google Fit		API de Sensores de Android
Confidencialidad	Sí.	Operación local. Permisos granulares. Almacenamiento cifrado. Contemplado en el modelo de seguridad de Android.	No.	Basada en la nube. Permisos generales.	No. Permiso general.
Integridad	Sí.	Operación local. Contemplado en el modelo de seguridad de Android.	No.	Basada en la nube.	Sí. Operación local.
Disponibilidad	Sí.	Operación local.	No.	Basada en la nube.	Sí. Operación local.
Autenticidad	Sí.	Permisos granulares. Verificación del origen. Contemplado en el modelo de seguridad de Android.	Sí.	Mecanismo de fuente de datos.	Sí. Acceso directo a los sensores.

Tabla I
COMPARATIVA DE SEGURIDAD ENTRE HEALTH CONNECT, GOOGLE FIT Y API DE SENSORES DE ANDROID.

- **Autenticidad:** La API de Sensores de Android garantiza la autenticidad de los datos al proporcionar acceso directo a los sensores del dispositivo. Esto implica que la información registrada proviene exclusivamente de la fuente correspondiente, sin riesgo de alteraciones en el origen.

Como se puede comprobar fácilmente en la tabla I, *Health Connect* es la única solución que cumple todos los pilares de seguridad. Esto nos permite confirmar que, efectivamente, *Health Connect* supone una mejora en términos de seguridad respecto a sus predecesoras.

V-B. Privacidad en Health Connect

La privacidad se basa en una serie de criterios cuya particularización al caso de las aplicaciones móviles la han llevado a cabo autoridades reguladoras, como la Agencia Española de Protección de Datos (AEPD) en España [24] o la Comisión Nacional de la Informática y las Libertades (CNIL) en Francia [25]. Para evaluar la privacidad en *Health Connect* y compararla con otras soluciones alternativas, se han seleccionado dos¹¹ criterios que, en nuestra opinión, son clave en el tratamiento de los datos de salud: la minimalidad de los datos y la capacidad del usuario para revocar su consentimiento.

Minimalidad de los datos Implica que solo se recojan aquellos estrictamente necesarios para la finalidad prevista, evitando un tratamiento excesivo; por ejemplo, una aplicación que realiza el seguimiento de los pasos diarios no debería acceder al sensor de presión arterial si solo cuenta el número de pasos.

Capacidad del usuario para revocar el consentimiento

Garantiza que cualquier persona pueda retirar su autorización para el uso de sus datos en cualquier momento, por ejemplo, al revocar el acceso a alguno de sus datos de salud.

De manera similar a lo expuesto en la sección V-A, estudiar si es posible garantizar plenamente cada uno de estos criterios queda fuera del alcance de este estudio, ya que, en última instancia, es la implementación específica de la aplicación

¹¹Por razones de espacio se han seleccionado estos dos, críticos en nuestra opinión. Esto no significa que el resto de criterios recogidos en las dos referencias [24] y [25] no deban ser estudiados para disponer de un estudio más completo.

que gestiona los datos de salud la que determina su uso, compartición y almacenamiento. No obstante, evaluaremos si cada solución incorpora mecanismos que permitan a desarrolladores y usuarios cumplir con los criterios seleccionados.

Teniendo esta consideración en cuenta, y los criterios de privacidad seleccionados para realizar la comparación, en la tabla II se muestra una comparativa de privacidad entre *Health Connect*, Google Fit y la API de Sensores de Android.

Evaluación de los mecanismos ofrecidos por *Health Connect* para cumplir cada uno de los criterios seleccionados:

- **Minimalidad de los datos:** *Health Connect* ofrece un control granular sobre el acceso a los datos de salud, lo que constituye un mecanismo que facilita a desarrolladores y usuarios cumplir con el criterio de minimalidad de los datos.
- **Capacidad del usuario para revocar el consentimiento:** El control granular, a nivel de dato, que *Health Connect* proporciona a los usuarios y la operación local permite que dispongan de medios suficientes para ejercer sus derechos de revocación del consentimiento.

Evaluación de los mecanismos ofrecidos por Google Fit para cumplir cada uno de los criterios seleccionados:

- **Minimalidad de los datos:** Google Fit se basa en permisos de acceso generales, por lo que no proporciona mecanismos que faciliten cumplir con la minimalidad de los datos.
- **Capacidad del usuario para revocar el consentimiento:** Google Fit no proporciona mecanismos que faciliten a los usuarios revocar su consentimiento de manera sencilla. Aunque el usuario revoque los permisos de acceso en su dispositivo, no se garantiza que los datos ya almacenados en la plataforma dejen de ser utilizados o compartidos.

Evaluación de los mecanismos ofrecidos por la API de Sensores de Android para cumplir cada uno de los criterios seleccionados:

- **Minimalidad de los datos:** De modo similar a como sucede con Google Fit, la API de Sensores de Android se basa en un único permiso de acceso (BODY_SENSORS), por lo que no aporta mecanismos que faciliten cumplir con la minimalidad de los datos.
- **Capacidad del usuario para revocar el consentimiento:** Gracias al permiso de gestión de acceso a los sensores y

Criterio de Privacidad	Soluciones					
	Health Connect		Google Fit		API de Sensores de Android	
Minimalidad de los Datos	Sí.	Permisos granulares.	No.	Permiso general. Basada en la nube.	No.	Permisos general.
Capacidad de revocar el consentimiento.	Sí.	Permisos granulares. Operación local.	No.	Basada en la nube.	Sí.	Permiso general. Operación local.

Tabla II
COMPARATIVA EN PRIVACIDAD ENTRE HEALTH CONNECT, GOOGLE FIT Y API DE SENSORES DE ANDROID.

a la operación local de la API de Sensores de Android, los usuarios disponen de medios suficientes para ejercer sus derechos de revocación del consentimiento.

Como se puede comprobar fácilmente en la tabla II, *Health Connect* es la única solución que cumple todos los criterios de privacidad. El análisis de los mecanismos de privacidad utilizados por cada una de las soluciones estudiadas nos ha permitido confirmar que, efectivamente, *Health Connect* supone una mejora en términos de privacidad respecto a sus predecesoras.

VI. DISCUSIÓN

El análisis realizado se centra en las soluciones que utilizan las aplicaciones, aquello que se ejecuta en el contexto de un dispositivo. Un estudio completo sobre las garantías que una aplicación ofrece en términos de seguridad y privacidad requeriría un estudio de todos los elementos del ecosistema en que lleva a cabo sus funciones. En este tipo de estudio se considerarían las cualidades de las soluciones basadas en la nube, la comunicación con terceros, los mecanismos de recogida y transmisión de datos, etc. Esta perspectiva es más propia de una auditoría de seguridad o de una evaluación de impacto de privacidad de un tratamiento de datos personales. No es este el enfoque elegido en nuestro estudio, que ofrece una guía para quienes se preguntan qué implicaciones tiene en realidad *Health Connect* en general, independientemente de la aplicación o de cada tratamiento de datos de salud en concreto.

Como se indicó en la sección V-B, se han seleccionado dos criterios para evaluar la privacidad que se consideran críticos: minimalidad en el acceso a datos personales y capacidad de revocar el consentimiento. Tratándose de dispositivos móviles, son dos sobre los que los usuarios pueden tener información a través de su dispositivo (los permisos que conceden o revocan en la sección de Ajustes) y sobre los que pueden actuar. Esto lo hace especial, puesto que no requiere que recurran a figuras externas como el Delegado de Protección de Datos para comprobarlos (minimalidad) o ejercerlos (consentimiento), algo que no ocurre en otros entornos. Sin embargo, esto no impide que otros criterios, como la “licitud, transparencia y lealtad” y los restantes recogidos en las guías [24], [25] deban ser evaluados para tener un estudio completo.

El cifrado de datos en *Health Connect* plantea varios interrogantes sobre su seguridad y robustez. Como se vio en la sección IV, aunque la documentación oficial de la plataforma menciona que *Health Connect* emplea un sistema de cifrado para proteger la información, no se especifica qué algoritmos criptográficos se utilizan ni cómo se garantiza la confidencialidad de los datos. Esta falta de transparencia

dificulta la evaluación de la seguridad del sistema, ya que un cifrado seguro debe ser público y auditable, lo que no es el caso en este contexto. En esa misma sección también se vio que es posible que *Health Connect* utilice el sistema de cifrado nativo de Android para proteger los datos, lo que aliviaría la necesidad de gestionar una clave de cifrado/descifrado de manera independiente, ya que Android implementa mecanismos de cifrado y gestión eficaces [6].

Sin embargo, el hecho de que no se especifique con detalle cómo *Health Connect* maneja estos procesos genera incertidumbre sobre su vulnerabilidad ante posibles ataques o brechas de seguridad. Aunque el cifrado proporcionado por Android puede ser eficaz, la falta de detalles específicos en la documentación de *Health Connect* sobre los mecanismos y algoritmos utilizados plantea serias dudas sobre la verdadera seguridad y privacidad de los datos de los usuarios.

Por último, conviene tener en cuenta que Google ha tenido un historial de retrasos en el cumplimiento de plazos y en la ejecución de cambios programados, como se evidenció en la adopción de la sección de seguridad de los datos en Google Play¹². Por ello, no resulta sorprendente que se repita esta situación con el anuncio de que la API de Google Fit dejará de utilizarse. Dichos retrasos pueden repercutir negativamente en la adopción de *Health Connect*. Además, la falta de claridad en la comunicación y la incertidumbre sobre las fechas de implementación de cambios críticos en servicios tan fundamentales como los que gestionan los datos de salud pueden generar desconfianza en los usuarios y dificultar la planificación a largo plazo por parte de los desarrolladores.

VII. CONCLUSIONES

Este estudio ha evaluado la seguridad y privacidad de *Health Connect* en comparación con otras soluciones de gestión de datos de salud en Android, como Google Fit y la API de Sensores de Android. Se ha observado que *Health Connect* introduce mejoras significativas en términos de seguridad, especialmente en los pilares de confidencialidad, integridad y disponibilidad. Asimismo, se han identificado avances en términos de privacidad, particularmente en la minimización de los datos y la capacidad de revocar el consentimiento.

Sin embargo, la falta de claridad en la documentación de *Health Connect*, especialmente en algunos aspectos del cifrado, plantea incógnitas que requieren una mayor transparencia por parte de Google si se busca una mejor acogida de la plataforma por parte de usuarios y desarrolladores.

En resumen, *Health Connect* marca un paso importante en la gestión segura de los datos de salud en Android.

¹²<https://support.google.com/googleplay/android-developer/answer/10787469>

Sin embargo, es necesario mejorar la transparencia en su documentación.

VIII. TRABAJO FUTURO

Como trabajo futuro, se propone profundizar en la integración de *Health Connect* dentro de los estándares de seguridad para aplicaciones móviles, como OWASP MASVS v2.1.0 [26], con el objetivo de evaluar empíricamente su eficacia en la gestión segura de datos de salud. En particular, sería relevante analizar controles como MASVS-STORAGE, MASVS-CRYPTO-2 y MASVS-PRIVACY, que abordan aspectos críticos de almacenamiento, cifrado y privacidad de la información. Este enfoque no solo contribuiría a fortalecer la protección de datos sensibles, sino que también establecería un marco de referencia para el desarrollo de aplicaciones móviles seguras, abriendo la puerta a investigaciones futuras sobre la escalabilidad de estos controles.

Adicionalmente, se propone ampliar el análisis de privacidad presentado en la sección V-B, incorporando un conjunto más amplio de criterios establecidos por organismos como la AEPD [24] y la CNIL [25]. Finalmente, se considera relevante incluir un análisis desde la perspectiva del usuario final, centrado en la usabilidad y comprensibilidad de la nueva interfaz de gestión de permisos granulares de *Health Connect*. Este tipo de estudio permitiría evaluar en qué medida el usuario medio es capaz de entender y gestionar adecuadamente sus configuraciones de privacidad, lo cual es crucial, ya que un sistema puede ser técnicamente seguro, pero ineficaz si no es comprensible para quienes lo utilizan.

AGRADECIMIENTOS

Este trabajo se incluye en las actividades del Proyecto Estratégico de Ciberseguridad App-PI (*App Privacy Impact*): Un ecosistema para la evaluación del impacto de apps para dispositivos móviles sobre la privacidad y seguridad de sus usuarios, el cual se realiza al amparo de un convenio de colaboración entre la Universidad de Valladolid y la S.M.E. Instituto Nacional de Ciberseguridad de España M.P., S.A. para la promoción de proyectos estratégicos de Ciberseguridad en España, en el marco de los Fondos del Plan de Recuperación, Transformación y Resiliencia, financiados por la Unión Europea (Next Generation).

REFERENCIAS

- [1] J. I. N. González and B. F. Morales, "Comunicación, Salud y Tecnología: mHealth," *Revista de Comunicación y Salud*, vol. 5, pp. 149–158, 2015. [Online]. Available: <http://doi.org/10.35669/>
- [2] C. D. Hylender, P. Langlois, A. Pinto, and S. Widup, "Data Breach Investigations Report," Verizon, Tech. Rep., 2024.
- [3] D. Seim, "El crecimiento explosivo de los dispositivos médicos portátiles," 2024, Último acceso: 10/02/2025. [Online]. Available: <https://www.halcousa.com/es/El-crecimiento-explosivo-de-los-dispositivos-m%C3%A9dicos-port%C3%A1tiles/>
- [4] Backlinko, "iPhone vs. Android User & Revenue Statistics (2024)," 2024, Último acceso: 10/02/2025. [Online]. Available: <https://backlinko.com/iphone-vs-android-statistics>
- [5] A. Aparicio, M. M. Martínez-González, and P. A. Criado-Lozano, "World App: El Secreto de tus Ojos está en los permisos Android," in *Actas de las IX Jornadas Nacionales de Investigación en Ciberseguridad, JNIC 2024*, A. M. R. Quintero, R. C. Guerrero, and Ángel J. Varela Vaca, Eds., 2024, pp. 245–252.
- [6] R. Mayrhofer, J. V. Stoep, C. Brubaker, D. Hackborn, B. Bonné, G. S. Tuncay, R. P. Jover, and M. A. Specter, "The Android Platform Security Model (2023)," 2023. [Online]. Available: <https://arxiv.org/abs/2503.02829>
- [7] G. Tuncay, "Android permissions: Evolution, attacks, and best practices," *IEEE Security & Privacy*, vol. PP, pp. 2–11, 2024.
- [8] Parlamento Europeo y Consejo de la Unión Europea, "Reglamento (UE) 2016/679 del Parlamento Europeo y del Consejo de 27 de abril de 2016 relativo a la protección de las personas físicas en lo que respecta al tratamiento de datos personales y a la libre circulación de estos datos (Reglamento General de Protección de Datos)," 2016, accedido el 18 de marzo de 2025. [Online]. Available: <https://eur-lex.europa.eu/legal-content/ES/TXT/?uri=CELEX%3A32016R0679>
- [9] U.S. Congress, "Health Insurance Portability and Accountability Act of 1996," 1996, accedido el 18 de marzo de 2025. [Online]. Available: <https://www.hhs.gov/hipaa/>
- [10] C. Braghin, S. Cimato, and A. Della Libera, "Are mhealth apps secure? a case study," in *2018 IEEE 42nd Annual Computer Software and Applications Conference (COMPSAC)*, vol. 02, 2018, pp. 335–340.
- [11] M. Fan, L. Yu, S. Chen, H. Zhou, X. Luo, S. Li, Y. Liu, J. Liu, and T. Liu, "An Empirical Evaluation of GDPR Compliance Violations in Android mHealth Apps," in *2020 IEEE 31st International Symposium on Software Reliability Engineering (ISSRE)*, 2020, pp. 253–264.
- [12] J. Benjumea, J. Roperio, O. Rivera-Romero, E. Dorronzoro-Zubiete, and A. Carrasco, "Assessment of the fairness of privacy policies of mobile health apps: Scale development and evaluation in cancer apps," *JMIR Mhealth Uhealth*, vol. 8, no. 7, p. e17134, Jul 2020. [Online]. Available: <http://mhealth.jmir.org/2020/7/e17134/>
- [13] A. Papageorgiou, M. Strigkos, E. Politou, E. Alepis, A. Solanas, and C. Patsakis, "Security and Privacy Analysis of Mobile Health Applications: The Alarming State of Practice," *IEEE Access*, vol. 6, pp. 9390–9403, 2018.
- [14] G. Tangari, M. Ikram, I. W. B. Sentana, K. Ijaz, M. A. Kaafar, and S. Berkovsky, "Analyzing security issues of Android mobile health and medical applications," *Journal of the American Medical Informatics Association*, vol. 28, no. 10, pp. 2074–2084, 08 2021. [Online]. Available: <https://doi.org/10.1093/jamia/ocab131>
- [15] G. Tangari, M. Ikram, K. Ijaz, M. A. Kaafar, and S. Berkovsky, "Mobile health and privacy: cross sectional study," *BMJ*, vol. 373, 2021. [Online]. Available: <https://www.bmj.com/content/373/bmj.n1248>
- [16] L. H. Iwaya, M. A. Babar, A. Rashid et al., "On the privacy of mental health apps," *Empirical Software Engineering*, vol. 28, no. 2, 2023. [Online]. Available: <https://doi.org/10.1007/s10664-022-10236-0>
- [17] K. Knorr and D. Aspinall, "Security testing for Android mHealth apps," in *2015 IEEE Eighth International Conference on Software Testing, Verification and Validation Workshops (ICSTW)*, 2015, pp. 1–8.
- [18] J. J. Flors-Sidro, M. Househ, A. Abd-Alrazaq, J. Vidal-Alaball, L. Fernandez-Luque, and C. L. Sanchez-Bocanegra, "Analysis of Diabetes Apps to Assess Privacy-Related Permissions: Systematic Search of Apps," *JMIR Diabetes*, vol. 6, no. 1, p. e16146, 2021.
- [19] Google, "Solicita acceso en segundo plano a los datos del sensor corporal," 2024, Último acceso: 20/02/2025. [Online]. Available: <https://developer.android.com/health-and-fitness/guides/health-services/background-body-sensors?hl=es-419>
- [20] S. Miller, W. B. Glisson, M. Campbell, and S. M. Sittig, "Risk Analysis of Residual Protected Health Information of Android Telehealth Apps," in *AMCIS*, 2019.
- [21] N. O. Ogwara, K. Petrova, M. L. B. Yang, and S. G. MacDonell, "A Risk Assessment Framework for Mobile Apps in Mobile Cloud Computing Environments," *Future Internet*, vol. 16, no. 8, p. 271, 2024.
- [22] A. C. Mendoza De Los Santos, J. A. Rios Reyes, and R. Y. Vasquez Chichayo, "Principales riesgos de seguridad en computación móvil en la nube: una revisión de la literatura," *Revista Científica de FAREM-Estef: Medio ambiente, tecnología y desarrollo humano*, vol. N° 45, pp. 206–220, 2023.
- [23] M. Armbrust, A. Fox, R. Griffith, A. D. Joseph, R. H. Katz, A. Konwinski, G. Lee, D. A. Patterson, A. Rabkin, I. Stoica, and M. Zaharia, "Above the Clouds: A Berkeley View of Cloud Computing," Tech. Rep. UCB/EECS-2009-28, Feb 2009. [Online]. Available: <http://www2.eecs.berkeley.edu/Pubs/TechRpts/2009/EECS-2009-28.html>
- [24] Agencia Española de Protección de Datos (AEPD), "El deber de informar y otras medidas de responsabilidad proactiva en apps para dispositivos móviles," Agencia Española de Protección de Datos, Tech. Rep., septiembre 2019. [Online]. Available: <https://www.aepd.es/sites/default/files/2019-11/nota-tecnica-apps-moviles.pdf>
- [25] Commission Nationale Informatique & Libertés (CNIL), "Recommandation relative aux applications mobiles," Commission Nationale Informatique & Libertés, Tech. Rep., enero 2024. [Online]. Available: <https://www.cnil.fr/sites/cnil/files/2024-09/recommandation-applications-mobiles.pdf>
- [26] OWASP Foundation, *OWASP Mobile Application Security Verification Standard (MASVS)*, 2024, versión 2.1.0. [Online]. Available: <https://github.com/OWASP/owasp-masvs/releases/tag/v2.1.0>